

Project scope:

The project is an automated web application penetration testing framework, this is a tool meant to automatically scan web applications for common security vulnerabilities. The tool will test for vulnerabilities such as cross site scripting or SQL injection. The problem this project solves is mainly time constraints, as checking every point of a web application manually would take far too much time. Therefore, this framework will seek to streamline that, doing so automatically, allowing the user to focus on more complex tasks, like solving those vulnerabilities. This project will allow me to learn cybersecurity concepts while providing tangible proof of my coding ability and project management. The framework should crawl through a web application, finding every aspect of the application, test said application for a number of common security risks, and return a report listing them out.

Out of scope: This section is used for what may not be possible in the timeframe for this project.

- Implementing every type of vulnerability that could be incorporated.
- Detecting advanced security risks.
- Creating my own intentionally vulnerable web applications to test with this framework
- Web dashboard that could include previous results
- AI analysis on how to fix the found risks.

Minimum Viable Product:

This section is meant to define the minimum requirements for the project to be considered completed.

1. The framework can accept a website URL

2. Crawl the intended website
3. Find pages/forms/parameters
4. Perform 3-5 security checks
5. Identify and structure findings
6. Generate an HTML report

Requirements:

The framework is meant to take a user's input of a website URL, for the purposes of the project in the given time frame will be intentionally vulnerable web applications like OWASP (Open Worldwide Application Security Project) Juice Shop and DVWA (**Damn Vulnerable Web Application**). The applications should be properly formatted, and able to be connected to by the program. The framework's output should be an HTML report detailing every aspect of the application that was discovered during its crawl, each security risk detected by the program including: risk severity, where the risk was found, a description of what the risk is, and a recommendation of how to fix said risk. The report should be able to open in a browser web page showing the results neatly and clearly.

Vulnerabilities: The framework is meant to test applications for web vulnerabilities, as such approximately 3-5 should be chosen to test for the minimum viable product, the vulnerabilities chosen are:

- Missing or improperly configured security headers
- Cross-Site Scripting (XSS)
- SQL Injection (SQLi)
- Insecure Direct Object References
- Sensitive Data Exposure